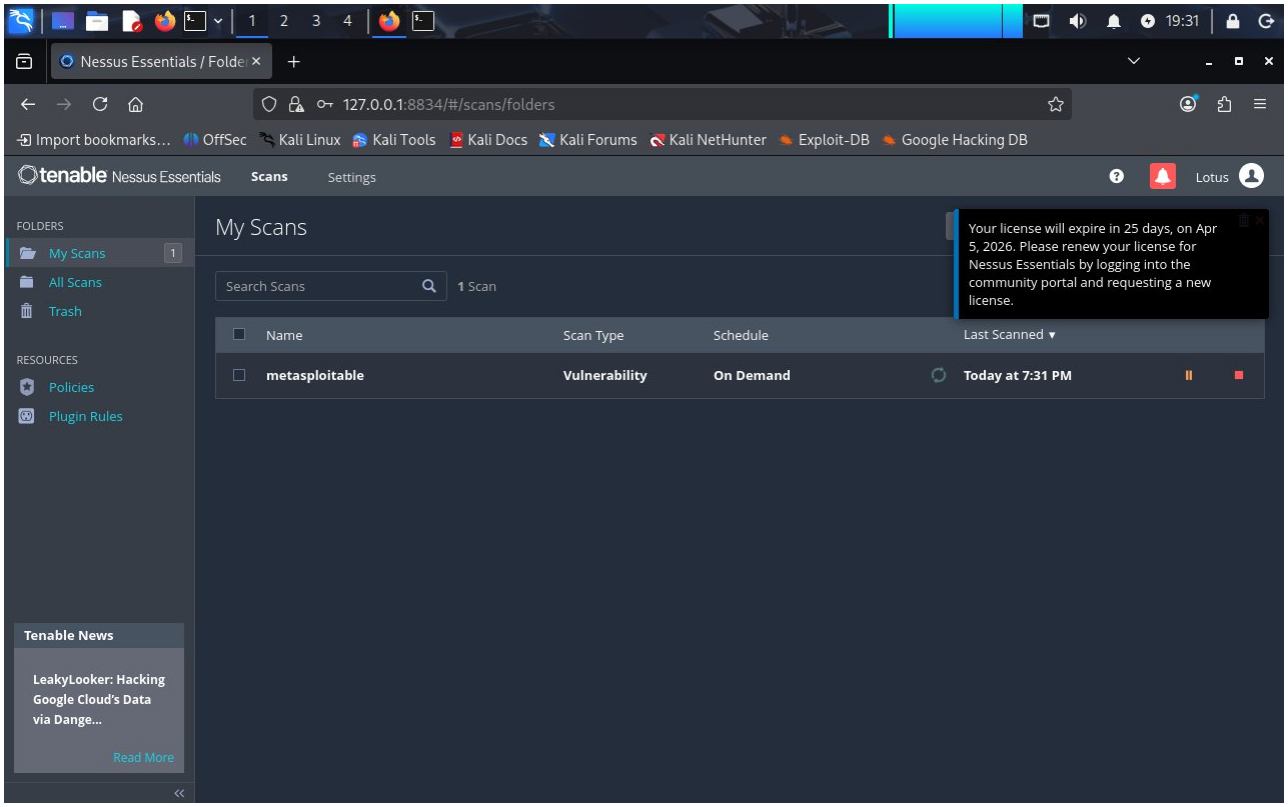
W12d1 report tecnico

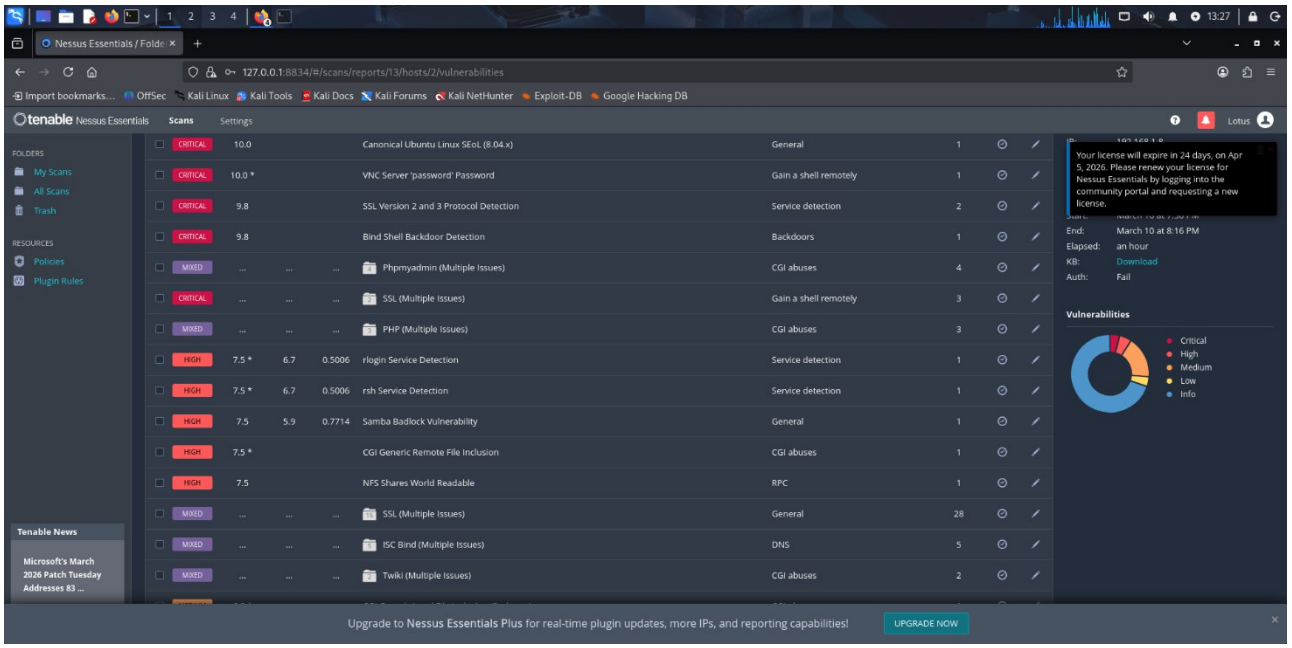
Ho analizzato tramite nessus avviando una kali in scheda con bridge le vulnerabilità di una metasploitable sempre con scheda con bridge.

Dopo aver installato nessus e avviato il servizio tramite il terminale di kali usando il comando: “Service start nessus”, ho aperto il browser e nella barra di ricerca ho digitato “htttps//127.0.0.1:8834” per accedere all’interfaccia di nessus.

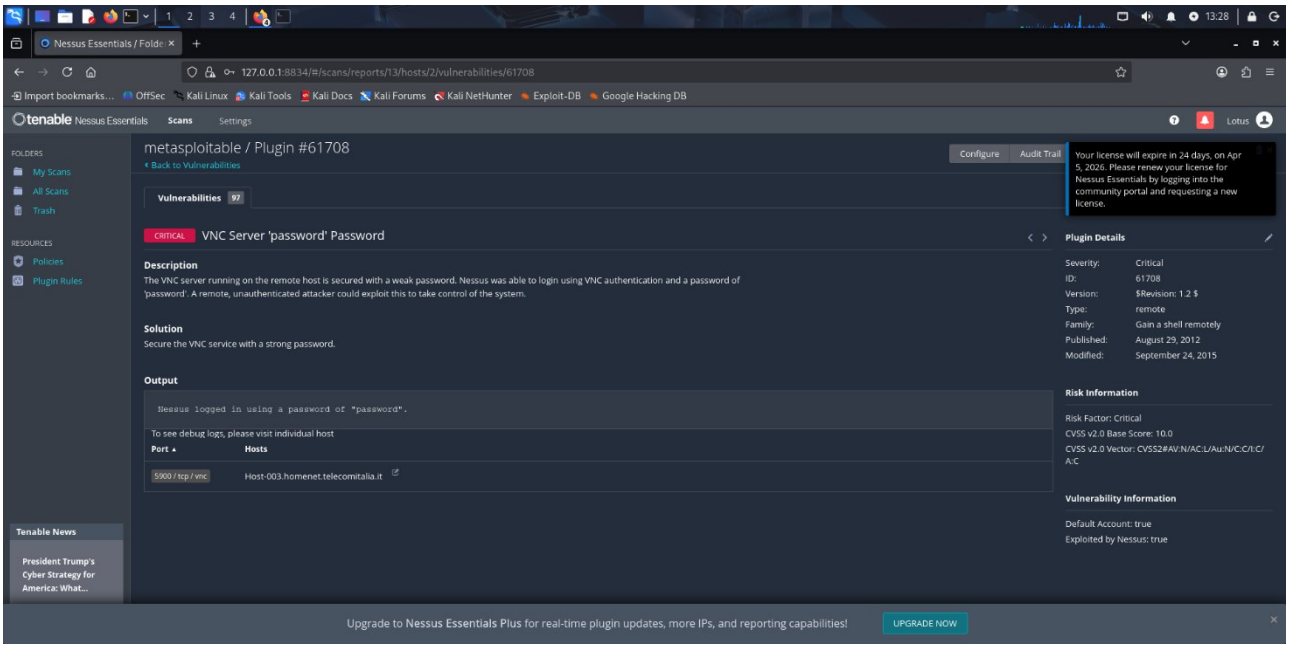
Ho avviato uno scan su metasploitable con indirizzo ip 192.168.1.8 e ho atteso la fine.



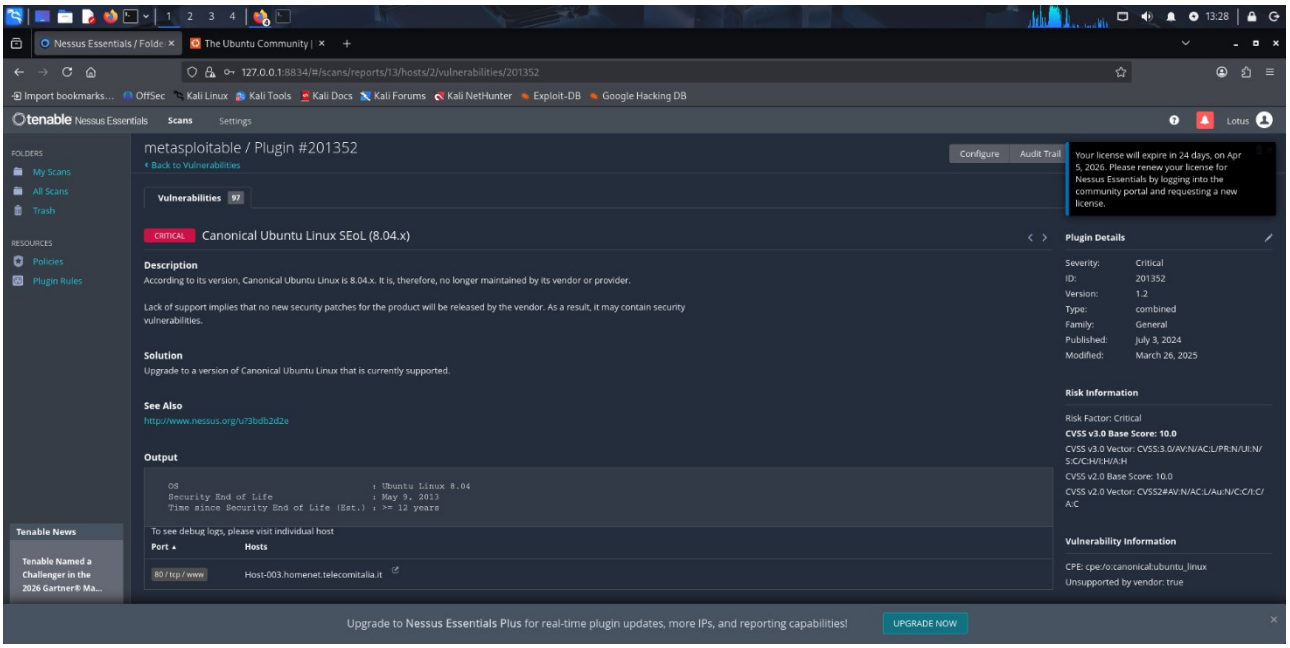
Alla fine dello scan sono state trovate circa un centinaio di vulnerabilità e ne ho analizzate alcune:



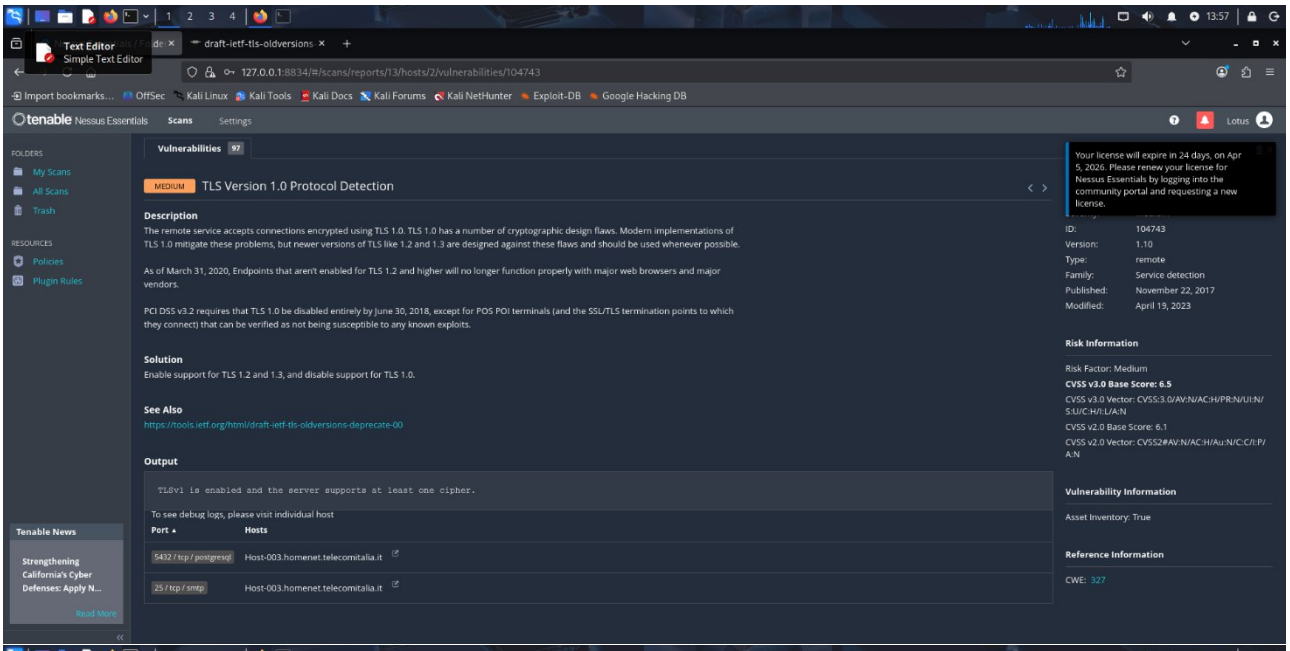
- Bruteforce con password comuni
  Sullla porta 5900 era attivo il server VNC, al quale nessus è riuscito ad accedere usando una password debole ovvero:”password”. Specificando che un attaccante non autenticato potrebbe facilmente sfruttare questa vulnerabilità per prendere il controllo del sistema. Il consiglio/la soluzione è di aggiornare con una password unica e di sicurezza forte

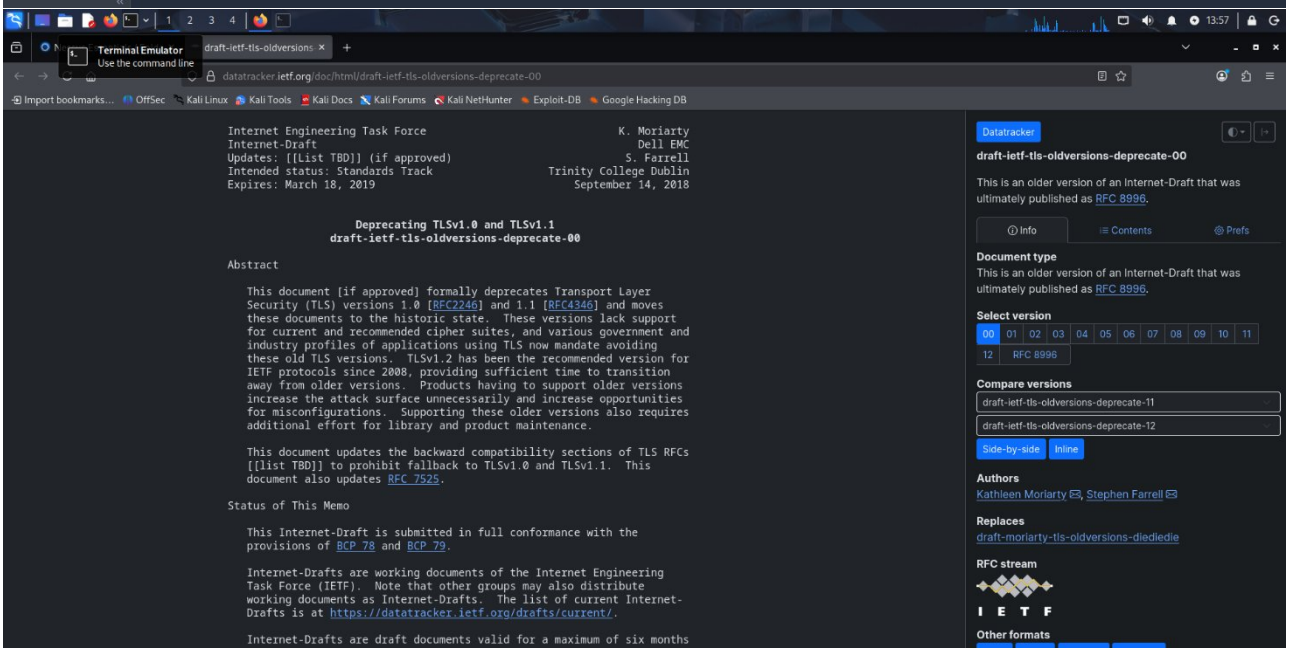


- Versione obsoleta os
  Sulla porta 80 è riuscito ad ottenere informazioni sul sistema operativo. Specificando che quest’ultimo appartiene ad una versione obsoleta, vecchia, del sistema operativo che non viene piu’ gestita dal provider. Quindi la mancanza di supporto potrebbe portare a molte vulnerabilità. Il consiglio è ovviamente quello di aggiornare il sistema operativo.



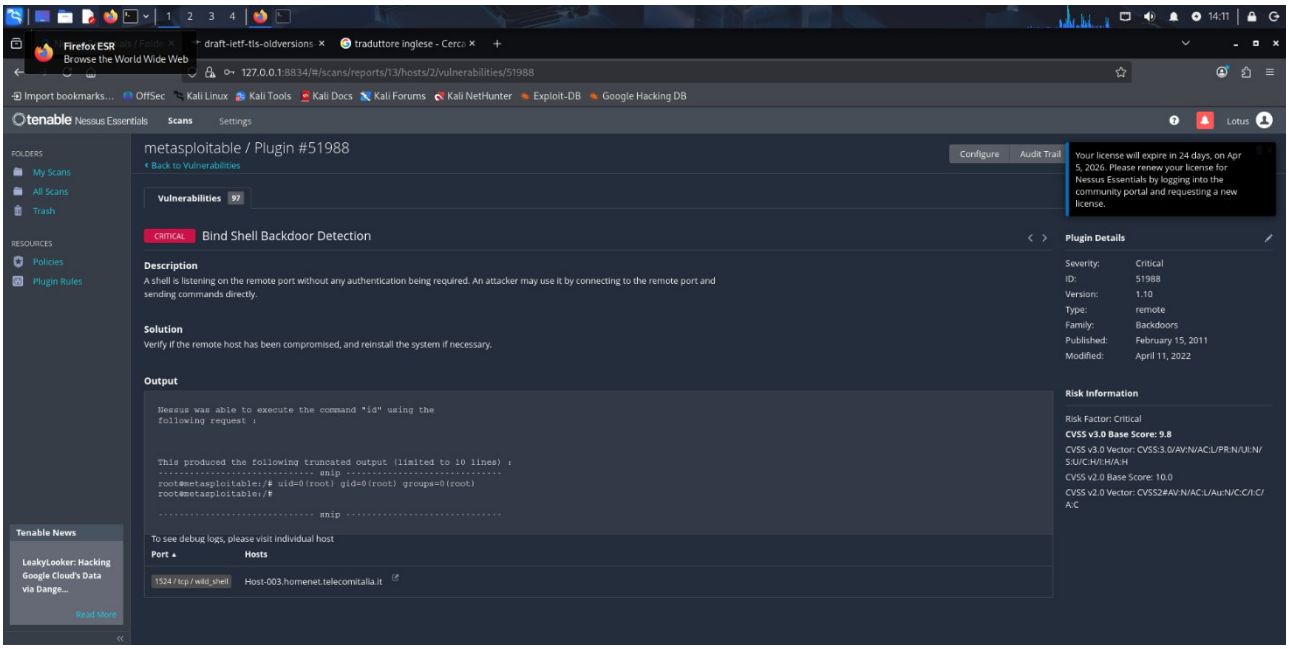
- Porta 25 e porta 5432 TLS 1.0
  Su queste due porte è stato trovata una vulnerabilità riguardante la gestione dell'integrità e privacy dei dati. Tramite il link fornito da nessus stesso ho cercato le informazioni necessarie per capire cosa facesse il servizio e perché fosse vulnerabile. Praticamente il TLS (Transport Layer Security) è un protocollo di sicurezza che dovrebbe occuparsi di fornire privacy e integrità dei dati per le comunicazioni in internet. Ma si è scoperto che la versione 1.0 presenta difetti di fabbrica. Il servizio accetta connessioni crittografate le quali grazie a questi difetti di fabbrica gli attaccanti possono decifrare con pochissime difficoltà. Infatti dal 30 giugno 2018 lo standard di sicurezza PCI DSS V2.0 prevede che sulle macchine il TLS 1.0 debba essere disabilitato. Tranne per i terminali che possono essere identificati come non vulnerabili.
  La soluzione consigliata è quella di appunto disabilitare il supporto per TLS 1.0 e abilitare invece il supporto per TLS 1.2/1.3. Ovvero versioni che sono state progettate proprio per contrastare i problemi della precedente versione.





- Un'altra vulnerabilità critica è stata trovata sulla porta 1524.
  Su questa porta abbiamo una shell in ascolto che non richiede autenticazione. La shell è un terminale dal quale possiamo controllare l'intera macchina, non richiedendo autenticazione è ovviamente una delle vulnerabilità piu' ad alto rischio.
  La soluzione data da nessus è quella di verificare che l'host remoto non sia stato compromesso e di reinstallare il sistema. Ho voluto approfondire ulteriormente per quanto riguarda le verifiche poiché la soluzione non mi sembrava completa.
  Ciò che ho appreso è che alcune delle tecniche per la verifica da utilizzare sono:
  1) Guardare i log specifici per quella porta
  2) Controllare se sono stati creati utenti strani guardando /etc/passwd e /etc/sudoers.
  3) Verificare cosa sta ascoltando la porta in questione

4) Prima di reinstallare il sistema bisogna capire se la shell è stata installata da un attaccante o se fa parte di una vulnerabilità del sistema. Perché se il caso fosse il secondo vuol dire che reinstallare soltanto non risolverebbe il problema ma bisognerebbe aggiornare all'ultima versione(Consigliato in qualunque caso)



Queste erano alcune delle vulnerabilità trovate su metasploitable.
Dopo averle approfondite ho riportato le varie soluzioni.